Full Stack Web Security & Ethical Hacking Blueprint

Comprehensive Developer Masterclass & Practical Guide

CYBERSECURITY

Author / Publisher: AppSec Threat Intelligence Group

© LearnForge Education Platform • View-Only Licensed Digital Edition

Chapter 1: Authentication & Session Token Hardening

Why LocalStorage is Unsafe for Tokens and How to Configure httpOnly Cookies

Storing authentication JWTs in client-side localStorage opens up total account takeover via any single Cross-Site Scripting (XSS) vulnerability.

By storing tokens in httpOnly, Secure, SameSite=Lax/Strict cookies, browser JavaScript cannot access the token, preventing exfiltration.

```
// Hardened Cookie Configuration
res.setHeader("Set-Cookie", serialize("auth_token", token, {
  httpOnly: true,
  secure: process.env.NODE_ENV === "production",
  sameSite: "lax",
  path: "/",
  maxAge: 60 * 60 * 24 * 7, // 7 days
}));
```

Key Takeaways & Best Practices:

- Never trust user-supplied IDs without validating ownership in session context.
- Rotate and invalidate tokens immediately upon password reset.
- Implement cryptographically secure webhook signature verification.

Chapter 2: Rate Limiting & Anti-Scraping Defenses

Protecting digital product streams from distributed scraping

Rate limiting is crucial for sensitive file streaming endpoints. Without throttling, bad actors can script rapid automated downloads of complete digital asset libraries.

Key Takeaways & Best Practices:

- Rate limit sensitive endpoints by both User ID and IP address.
- Log anomaly bursts to security telemetry pipelines.